ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Schneider Electric PowerLogic ION9000 · Component type: **Embedded Device (EDR) - power/energy meter** · Target SL = SL 3

Where to work	**ION Setup** (Setup Assistant › Security › Security Mode) with the encrypted **Security Configuration File (.scf)**; embedded **webpages (HTTPS)**; **front-panel display**; **SFTP/SSH**. Physical **revenue-lock switch** + anti-tamper seals + lock LED.
Interfaces / ports	HTTPS **443** (+HTTP redirect); SFTP **22**; Modbus TCP **502**; ION **7700**; **Secure ION/TLS 7443**; DNP **20000**; DLMS **4059**; BACnet/IP **47808**; IEC 61850 **102**; EtherGate **7801**; SNMP **161** (v1/v2, default off).
Firmware note	**Advanced security mode** is default from firmware **v3.0.0+** (up to 50 users). Confirm model **METSEION9xxxx** and firmware in ION Setup / display. Ships with a **self-signed** SSL cert (replace with CA-signed).
How to read	Default read-only (ION Setup read-only account, .scf review, front-panel). Native how-to + external-tool validation + pass. Write/exploit tools = **isolated + written authorization**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user I&A;	ION Setup › Setup Assistant › **Security › Security Mode = Advanced**; open the **.scf** and confirm per-user accounts (USER1..USER50), that **webpages require sign-in**, and the **display config password** is set. **Test:** connect via ION Setup with no credentials -> denied; browse the meter webpage -> login required; front-panel config prompts for password. **Ext. tools:** ION Setup; web browser (HTTPS); SFTP client; ReadOnlyEnum.	Every human interface (ION Setup, webpages, display, SFTP) authenticates; no anonymous/shared path.	Standard mode = weak -> must use Advanced.
SR/CR 1.2	Device & software-process I&A;	Confirm **Secure ION (ION over TLS, 7443)** is enabled for machine-to-machine; native ION/Modbus/DNP/DLMS/BACnet are **unauthenticated** -> rely on Secure ION or segmentation. **Test (isolated):** connect an unprovisioned client to 7443 -> rejected; capture shows TLS on 7443, cleartext on 502/7700. **Ext. tools:** Wireshark (Modbus/ION/TLS dissector; confirm 7443 TLS); Modbus/ION test client; Nmap; ReadOnlyEnum.	Secure ION peers authenticate; unauthenticated protocols compensated by segmentation.	Native ION/Modbus unencrypted by design.
SR/CR 1.3	Account management	ION Setup **Security** wizard › user accounts: review the up-to-50 user slots, leave unused users inactive, change the default USER1/USER2 credentials, and assign least-privilege access levels; no shared logins. **Ext. tools:** ION Setup (.scf user/access-level review).	Named least-privilege users; unused slots inactive; factory defaults changed.	
SR/CR 1.4	Identifier management	Confirm each active user has a unique identifier and the meter has a unique network identity (IP / device name); no reuse. **Ext. tools:** ION Setup (user + comms identity review).	Unique user and device identifiers; no reuse.	
SR/CR 1.5 / 1.7	Authenticator mgmt & password strength	In the ION Setup Security wizard set **Password Complexity = IEEE 1686-2013** or **NERC CIP-007-5** and **Minimum Password Length** (6-16); **change the default password (0)** for USER1/USER2. Confirm rotation. **Ext. tools:** ION Setup (policy review); attempt weak password -> rejected.	Complexity + min length enforced; default password changed; rotation works.	Some ION clients limit to 6 alphanumeric — verify compatibility.
SR/CR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.8	PKI certificates	The meter ships a self-signed SSL certificate; upload a **CA-signed certificate** (meter webpages / ION Setup) for HTTPS and Secure ION and verify validity/expiry. **Ext. tools:** Browser cert view; openssl x509 (validity/chain).	CA-signed certificate installed and valid; default self-signed replaced.	
SR/CR 1.9	Strength of public key auth	Confirm Secure ION / HTTPS TLS uses strong ciphers and keys (>=2048 RSA / ECC); no weak or expired certificate. **Ext. tools:** testssl.sh (:443); openssl (key/algorithm).	Strong TLS crypto; weak/self-signed cert replaced.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.10	Authenticator feedback	Confirm ION Setup, the meter webpages, and the front-panel display mask password entry (no cleartext echo). **Ext. tools:** Visual verification at each interface.	Authenticators obscured on all interfaces.	
SR/CR 1.11	Unsuccessful login attempts	ION Setup Security wizard › **Define lockout and event timeout**: set **lockout after N failed attempts**, **lockout duration**, and per-protocol event timeout. **Test:** exceed the threshold and confirm lockout + a lockout event. **Ext. tools:** ION Setup (repeated invalid logins, authorized) to confirm lockout; event-log review.	Excess failed attempts trigger lockout for the configured duration and are logged.	Native lockout present (unlike some IEDs).
SR/CR 1.12	System use notification	The meter has limited banner capability; set an approved notice on the webpage/display where supported, otherwise enforce the banner at the access workstation/HMI as a compensating control. **Ext. tools:** Visual verification.	Approved use notice where supported (Partial; compensating at HMI/EWS).	Compensating.
SR/CR 1.13	Access via untrusted networks	Segment the meter; use Secure ION/HTTPS/SFTP only over untrusted paths; disable unused protocols; remote access brokered. Confirm no unauthenticated protocol is exposed off-segment. **Ext. tools:** Nmap from each segment; firewall-rule review.	Only secure channels reachable off-segment; unauthenticated protocols contained.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	In the .scf confirm each user's **access levels** (Read, Time Sync, Peak Demand Reset, Comm Config, Test Mode, Full Meter Config, **Security Config**) follow least privilege. **Test:** a read-only user cannot change configuration or security. **Ext. tools:** ION Setup (per-user access review); attempt privileged write as read-only user.	Least privilege enforced across the 7 access types; privileged actions denied.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use control for portable/mobile devices	The meter has no user removable media; control the optical/serial diagnostic port and enforce a removable-media policy on the engineering workstation. **Ext. tools:** Physical inspection; EWS removable-media policy.	Portable-media use controlled at the meter and the workstation.	
SR/CR 2.4 (+ EDR 2.4)	Mobile code	No general-purpose mobile code runs on the meter; confirm only signed firmware and the vendor webpage content execute. **Ext. tools:** ION Setup (firmware / webpage review).	Only trusted signed code runs; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	Confirm the **inactivity timeout** that requires re-sign-in for webpages, display, and the Secure ION protocol. **Ext. tools:** Manual idle test on webpage/display.	Inactivity timeout re-prompts on webpages/display/Secure ION.	
SR/CR 2.6	Remote session termination	Confirm sessions can be terminated (ION Setup disconnect) and that the meter inactivity timeout closes idle webpage / Secure ION sessions; failed-logon lockout applies. **Ext. tools:** ION Setup; meter webpage (timeout/lockout test).	Remote sessions terminable on demand and on inactivity.	
SR/CR 2.7	Concurrent session control	The meter shares a bounded connection pool across ION / Modbus / DNP / DLMS; confirm concurrent access is limited and monitored. **Ext. tools:** ION Setup (connection status); Wireshark.	Concurrent connections bounded and monitored.	
SR/CR 2.8 / 2.12	Auditable events & non-repudiation	Review the meter **event log** (5,000 records) — valid/invalid login and lockout events (priorities 0/128/255); confirm the embedded user on changes; enable **syslog offload** for retention. **Test:** make a config change -> event with user + time. **Ext. tools:** ION Setup / Power Monitoring Expert (event-log/audit); syslog listener.	Security events logged with user + timestamp; offloaded to syslog; changes attributable.	
SR/CR 2.9	Audit storage capacity	The meter event log is a rolling buffer; confirm a designated reader and threshold and offload events to **Syslog** for retention. **Ext. tools:** ION Setup (event-log settings); syslog/SIEM retention.	Log capacity known; events offloaded and retained; threshold alert.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM/syslog collector alerts on forwarding failure; the meter continues logging locally (overwrite oldest) so events are not silently lost. **Ext. tools:** SIEM alerting configuration.	Audit-failure alerting defined; local logging continues.	
SR/CR 2.11	Timestamps	Confirm internal time sync / time-source integrity (broadcast time sync, NTP, or GPS) and that time-source changes are logged. **Ext. tools:** Wireshark (NTP); ION Setup time-source review.	Accurate synced time; time-source changes logged.	
EDR 2.13	Physical diagnostic & test interfaces	Control the meter optical/serial diagnostic ports and front panel; use the display configuration password and apply anti-tamper seals over the terminal/interface covers. **Ext. tools:** Physical inspection (seals / port covers).	Diagnostic/test interfaces controlled and sealed.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1 / 4.1	Communication integrity & confidentiality	Enable **Secure ION/TLS (7443)**, HTTPS (443, force redirect), SFTP, MQTT-TLS (8883), **Secure EtherGate**; confirm sensitive channels are TLS. Replace the factory **self-signed SSL certificate** with a CA-signed cert (ION Setup › upload custom SSL cert). **Ext. tools:** testssl.sh / sslscan on :443 and :7443; Wireshark (confirm TLS, no cleartext creds); openssl (cert chain).	Sensitive comms TLS-protected; CA-signed cert installed; weak protocols disabled.	
SR/CR 3.2 / 3.4	Malicious code & software integrity	Confirm **digitally signed firmware** (meter only accepts Schneider-signed firmware); protect the **.scf** (encrypted) and firmware/config baseline; source firmware from se.com. **Ext. tools:** Firmware signature verify during ION Setup/SFTP upgrade; se.com checksum.	Only signed firmware loads; .scf and config integrity protected.	
EDR 3.2	Protection from malicious code (component)	Confirm **Secure ION** is enabled and only Schneider-signed firmware runs, so the meter is protected from malicious code and its communications integrity is preserved at the component. **Ext. tools:** ION Setup (Secure ION status / firmware); Wireshark.	Secure ION active; only signed firmware runs; component comms integrity preserved.	EDR-specific.
SR/CR 3.3	Security functionality verification	Use ION Setup's **Verify security settings** / human-readable security report to confirm settings against the baseline after any change; compare the .scf to the approved baseline. **Ext. tools:** ION Setup (verify-settings report); .scf compare.	Security settings match the baseline after change.	
SR/CR 3.5	Input validation	Confirm the meter tolerates malformed Modbus / DNP3 / ION protocol frames without faulting or loss of measurement. **ISOLATED only:** fuzz the protocol interfaces on a representative unit and watch comms/measurement health. **Ext. tools:** Protocol fuzzer / traffic generator (ISOLATED); Wireshark.	No crash or loss of measurement on malformed input.	Do NOT fuzz production.
SR/CR 3.6	Deterministic output	If digital/relay control outputs are configured, verify their state on fault / comm loss; if the meter is measurement-only, record that and confirm measurement/logging integrity instead. **Ext. tools:** ION Setup (digital-output configuration).	Defined output state on fault (or measurement-only recorded).	
SR/CR 3.7	Error handling	Confirm the meter handles faults/errors gracefully (diagnostics, no loss of measurement or info leakage). **Ext. tools:** ION Setup (meter diagnostics review).	Graceful fault handling; no unsafe state or info leak.	
SR/CR 3.8	Session integrity	Secure ION / HTTPS (TLS) protect sessions against replay/hijack; confirm secured channels are in use for engineering and data access. **Ext. tools:** Wireshark (session inspection).	Sessions integrity-protected on TLS channels.	
SR/CR 3.9	Protection of audit information	Protect the event log and Syslog transport, and restrict Security-Config access so logs cannot be cleared/altered by unauthorized users. **Ext. tools:** ION Setup (access-level review); SIEM access review.	Audit records protected from unauthorized read/modify/delete.	
EDR 3.10	Support for updates	Verify signed firmware upgrade path via ION Setup firmware upgrade / SFTP; leave Secure ION enabled for upgrades. **Ext. tools:** ION Setup firmware upgrade (authorized window).	Signed firmware update supported and verified.	EDR-specific.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
EDR 3.11	Physical tamper resistance & detection	Verify the **revenue-lock switch** (sealed cover, toggle, lock LED) and **anti-tamper sealing points** (voltage/current terminal covers) are sealed; breaking seals voids revenue certification. **Ext. tools:** Physical inspection of seals + lock LED state.	Meter revenue-locked; anti-tamper seals intact; lock LED = ON.	EDR-specific.
EDR 3.12 / EDR 3.14	Roots of trust / boot integrity	Firmware is signed for authenticity; note the platform provides **no hardware root-of-trust / secure-boot anchor** -> record as residual risk with compensating controls (segmentation, physical security). **Ext. tools:** Vendor documentation review.	Signed firmware authenticity; absence of HW root-of-trust dispositioned as residual risk.	Honest platform limit.
EDR 3.13	Provisioning asset-owner roots of trust	Upload the asset owner's CA-signed certificate (asset-owner trust anchor for HTTPS / Secure ION) and confirm the meter uses it rather than the factory self-signed certificate. **Ext. tools:** ION Setup (certificate upload / verify).	Asset-owner certificate provisioned and in use.	EDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.2	Information persistence	On decommission or repurpose, perform a meter reset to factory defaults to clear users, configuration, and logs, and secure/remove any exported data so credentials and configuration are not recoverable. **Ext. tools:** ION Setup (master reset); verify config cleared.	Sensitive data purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	Confirm TLS on Secure ION/HTTPS/SFTP with strong ciphers; replace self-signed cert; disable weak protocol versions. **Ext. tools:** testssl.sh / sslyze on :443 and :7443.	Modern TLS + strong ciphers; self-signed default replaced.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1 / 5.2	Segmentation & zone boundary	Confirm the meter is in a segmented zone; only required ports open at the boundary; disable unused protocols to shrink attack surface. **Ext. tools:** Nmap by zone (502/7700/7443/443/22...); firewall review.	Meter segmented; only required protocols reachable; boundary enforced.	
SR/CR 5.3	General Purpose Person-to-Person Communication Restrictions	**N/A.** Embedded device has no general-purpose person-to-person communications (email/IM/web).	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 5.4	Application Partitioning	**N/A.** Single-purpose device; no separable applications to partition (handled at the host/SCADA layer).	N/A - justification recorded (not assessed as a control).	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1 / 6.2	Audit accessibility & monitoring	Confirm the event log is readable/exportable and **syslog offload** ships events to the SIEM; assign a designated reader for the 5,000-record threshold; passive OT monitoring on the segment. **Ext. tools:** Syslog listener (`nc -lu 514`); Power Monitoring Expert; passive OT monitor.	Events accessible/exportable; forwarded to SIEM; monitoring active.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Disable unused protocols/ports to reduce exposure; segment; rely on network rate-limiting. **ISOLATED:** confirm the meter keeps measuring under protocol flooding. **Ext. tools:** Protocol fuzzer / traffic generator (ISOLATED); Wireshark.	Meter continues measuring/logging under load; surface minimized.	
SR/CR 7.2	Resource management	Confirm the meter limits resource exhaustion — the bounded connection pool and protocol rate handling prevent a flood from denying metering/logging; monitor connection count and comms health. **Ext. tools:** ION Setup (diagnostics); traffic generator (ISOLATED).	Resources bounded; metering/logging continue under load.	
SR/CR 7.3 / 7.4	Backup & recovery	Capture a verified backup of the **.scf** and firmware/configuration; test restore on a spare meter. **Ext. tools:** `sha256sum` of .scf/config; ION Setup restore (lab).	Recent verified .scf + config backup; restore tested.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6 / 7.7	Config settings & least functionality	Verify meter security settings against the **Default meter security settings** table; **disable unused protocols and change default ports** (Disabling/enabling protocols page) — e.g., SSH terminal off, SNMP off, unused Modbus/DNP/BACnet off. **Ext. tools:** Nmap (open protocols/ports); ION Setup verify-security-settings report.	Only required protocols enabled; ports hardened; settings match baseline.	
SR/CR 7.8	Component inventory	Capture model (METSEION9xxxx), firmware, option modules, and enabled protocols via ION Setup / display for the inventory. **Ext. tools:** ION Setup; ReadOnlyEnum.	Complete model/firmware/protocol inventory captured.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
ION Setup	Native security config & .scf review (all)	Open the Setup Assistant / Security wizard with a read-only account; review Security Mode, users/access levels, password & lockout policy, protocol enable/disable, and the SSL cert.	Read-only account; unlock only for change tests.
Meter webpages (HTTPS) / front-panel display	Interface auth & settings review (1.1, 2.5)	Confirm sign-in is required, banner/lock state, and inactivity timeout on webpages and the display.	HTTPS only; authorized login.
Gateway Backup (.scf) + sha256sum	Baseline, drift, recovery (3.4, 7.3)	Export the encrypted .scf; hash it to detect drift; restore on a lab meter to test recovery.	.scf holds security config — protect it.
testssl.sh / sslscan / sslyze	TLS/cipher/cert strength (3.1, 4.3)	`testssl.sh https://<meter>:443` and `:7443`; confirm TLS only, strong ciphers, and a CA-signed (not self-signed) cert.	Read-only/safe.
openssl	Certificate inspection (3.1, 4.3)	`openssl s_client -connect <meter>:7443 | openssl x509 -noout -issuer -dates`; confirm chain and validity.	Read-only.
Nmap / PortQry	Protocol/port exposure & segmentation (1.13, 5.x, 7.7)	`nmap -sT -p 502,7700,7443,443,22,20000,4059,47808,161 -T2 <meter>`; scan by zone; confirm unused protocols closed.	Tune timing on production.
Wireshark / tcpdump	Comm integrity & confidentiality (1.2, 3.1)	SPAN/tap; confirm 7443/443 are TLS and no cleartext credentials on 502/7700; AiTM inspection.	Passive; SPAN/tap only.
Modbus / ION test client	Unauthenticated-protocol exposure (1.2)	Read-only queries to confirm which protocols answer without auth; verify segmentation compensates.	Passive/read-only on production.
Power Monitoring Expert	Audit/event review & baseline (2.8, 6.1)	Review event log, user attribution, and configuration baselines; user attribution requires Advanced mode.	Read/compare baselines.
Syslog listener (nc / rsyslog)	Log offload verification (6.1, 6.2)	Stand up a listener; trigger a login/lockout event; confirm the meter forwards it to the SIEM.	Coordinate with SIEM team.

Tool / method	Verifies	How to use — steps / example	Constraints
ReadOnlyEnum	Host/network/protocol enumeration (7.8)	Enumerate exposed services/protocols read-only.	Read-only.
Protocol fuzzer / traffic generator	Input validation & DoS resilience (3.5, 7.1)	Malformed-frame / high-rate protocol testing while watching that measurement/logging continues.	ISOLATED/non-production; authorization.

Controlled - Project Use · Independent Assurance Authority · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.